POL-SEC-001

Política de Seguridad de la Información

Versión 3.2 | Vigente desde: 15 de enero de 2026 | Clasificación: Uso Interno

1. Objetivo

Establecer los principios, responsabilidades y controles necesarios para proteger la confidencialidad, integridad y disponibilidad de la información de la Corporación, sus clientes y empleados, conforme a las mejores prácticas internacionales (ISO 27001) y la normativa aplicable.

2. Alcance

Esta política aplica a todos los empleados, contratistas, proveedores y terceros que accedan, procesen o almacenen información de la Corporación, independientemente de su ubicación geográfica o del dispositivo utilizado.

3. Principios generales

- La información es un activo crítico de la Corporación y debe protegerse de forma proporcional a su valor y sensibilidad.
- Todo acceso a sistemas e información debe estar basado en el principio de mínimo privilegio.
- Los incidentes de seguridad deben reportarse de forma inmediata.
- El incumplimiento de esta política puede generar sanciones disciplinarias, incluyendo el despido, y acciones legales.

4. Clasificación de la información

Toda información debe clasificarse en una de las siguientes categorías: Pública, Uso Interno, Confidencial o Secreta. Los propietarios de la información son responsables de asignar y revisar periódicamente la clasificación.

4.1. Definiciones

Pública: Información que puede divulgarse libremente sin riesgo para la Corporación.

Uso Interno: Información de uso exclusivo de empleados y colaboradores autorizados.

Confidencial: Información cuya divulgación no autorizada puede causar daño moderado o significativo.

Secreta: Información altamente sensible (estrategia, datos personales sensibles, secretos comerciales).

4.2. Reporte de incidentes de seguridad

Todo empleado que detecte o sospeche un incidente de seguridad (acceso no autorizado, pérdida de dispositivo, phishing, malware, fuga de datos, etc.) debe reportarlo en un plazo máximo de **24 horas** a través de uno de los siguientes canales:

- Portal interno de Seguridad de la Información (recomendado)
- Correo electrónico: security@corporacion.com

- Línea telefónica de emergencia: +1-800-SEC-HELP (24/7)

El reporte debe incluir: descripción del incidente, fecha y hora aproximada, sistemas o datos afectados, y cualquier acción ya tomada. No se sancionará a quien reporte de buena fe un incidente.

5. Control de acceso

El acceso a sistemas y datos se otorga únicamente después de la aprobación del responsable del área y del equipo de Seguridad de la Información. Las credenciales son personales e intransferibles. Está prohibido compartir contraseñas o dejar sesiones abiertas en puestos de trabajo compartidos.

Las contraseñas deben tener un mínimo de 12 caracteres, combinar mayúsculas, minúsculas, números y símbolos, y renovarse cada 90 días. Se recomienda el uso de autenticación multifactor (MFA) en todos los sistemas críticos.

6. Uso de dispositivos y trabajo remoto

Los dispositivos corporativos deben tener el software de seguridad (antivirus, EDR, cifrado de disco) instalado y actualizado. Está prohibido almacenar información Confidencial o Secreta en dispositivos personales no gestionados o en servicios de nube no autorizados. Para el trabajo remoto se debe utilizar la VPN corporativa.

7. Responsabilidades

Empleados: Cumplir esta política, reportar incidentes y participar en las capacitaciones obligatorias de seguridad.

Gerentes: Asegurar que sus equipos conozcan y apliquen la política, y autorizar accesos de forma responsable.

Seguridad de la Información: Mantener esta política actualizada, monitorear el cumplimiento y gestionar incidentes.

8. Revisión y vigencia

Esta política se revisará al menos una vez al año o cuando existan cambios significativos en la tecnología, amenazas o requisitos legales. La versión vigente está publicada en el portal de Políticas Internas.

Documento aprobado por: Dirección de Seguridad de la Información y Comité de Riesgos
Próxima revisión programada: enero 2027